

Information Security Documentation

Ciunciusky Trust

SYSTEM	Hundie, an internal expense-management and bookkeeping application
SECURITY CONTACT	Alex Ciunciusky, Owner · alexbhp@gmail.com
EFFECTIVE	June 2026
REVIEW	At least once a year, and after any major change to the system

1. What we run and what data we hold

Hundie is a private bookkeeping application used by the trust's owner and one bookkeeping partner. It reads transaction history from the owner's own bank and credit-card accounts through Plaid, sorts each transaction by entity and expense category, and passes the categorized data to QuickBooks Online.

We store:

- Transaction records from Plaid: date, amount, description, and merchant.
- Plaid access tokens, which let the application pull new transactions.
- Account and category settings the owner configures.

We do not store bank login credentials. Those stay with Plaid. The application only ever holds a Plaid access token, never a username or password for a financial institution.

The application is hosted on Vercel. The database and user authentication run on Supabase, a managed PostgreSQL service.

2. Access and authentication

Signing in is required to use the application, and only the owner and the bookkeeping partner have accounts.

Administrative access to the systems that hold financial data (the Supabase project, the Vercel project, and the GitHub repository) is limited to the owner. Each of those accounts requires multi-factor authentication.

Inside the database, every table that holds financial data is protected by row-level security and is readable only by an authenticated session. The Plaid tables that hold the connection tokens and account mappings have no read access for the public application key at all. They can be reached only by a server-side service key.

That service key bypasses row-level security, so it is treated as a high-value secret. It is stored only in the server environment, is never sent to the browser, and is used only inside server-side routes that first confirm the user is signed in.

3. Encryption

In transit: all traffic uses HTTPS with TLS 1.2 or higher. This is enforced by Vercel and Supabase and cannot be downgraded by the application.

At rest: the Supabase database is encrypted with AES-256. On top of that, each Plaid access token is encrypted by the application with AES-256-GCM before it is written to the database, using a key held only in the server environment. A token read straight from the database is ciphertext and is useless without that key.

4. Secrets

All keys and tokens (the database service key, the Plaid client secret, and the token-encryption key) live in environment variables on Vercel and Supabase. They are not written into source code, and environment files are kept out of version control. The token-encryption key is also recorded in a password manager so it cannot be lost. If it ever changed, stored tokens would stop decrypting and the affected banks would be re-linked.

5. Vulnerability and patch management

Application dependencies are checked for known vulnerabilities with `npm audit` and GitHub Dependabot, and updated when issues are reported. The underlying servers, database engine, and network are managed and patched by Vercel and Supabase.

6. Data retention and deletion

Transaction data is kept while the owner needs it for bookkeeping. When a bank connection is removed in the application, the connection is revoked at Plaid and its stored token and account mappings are deleted. Retention and deletion are described in full in the trust's Data Retention and Disposal Policy.

7. Vendors

The application relies on a small set of established providers: Plaid for bank data, Supabase for the database and authentication, Vercel for hosting, and QuickBooks Online for accounting. Financial transaction data is not sold or shared with anyone outside these providers, and it is not used for advertising.

8. Incident response

If a security problem is suspected, such as a leaked key, unexpected access, or a breach notice from a vendor, the owner will rotate the affected secret right away, remove and re-link any affected bank connection so a fresh token is issued, review recent access, and notify any affected party as required. The security contact named above is the point of contact.

9. Review

This document is reviewed at least once a year and after any significant change to how the application stores or handles financial data.